

Strengthening the MDCG Guidance on Cybersecurity for Medical Devices: A Legal Approach

Yeşiltuna, Oğuzhan; Su, Ruoxin; Kumar, Ashwinee; Quinn, Paul

Published in:
Cybersecurity

DOI:
[10.1007/978-3-031-94855-8_21](https://doi.org/10.1007/978-3-031-94855-8_21)

Publication date:
2025

License:
Other

Document Version:
Accepted author manuscript

[Link to publication](#)

Citation for published version (APA):
Yeşiltuna, O., Su, R., Kumar, A., & Quinn, P. (2025). Strengthening the MDCG Guidance on Cybersecurity for Medical Devices: A Legal Approach. In I. Praça, S. Bernardi, & P. R. M. Inácio (Eds.), *Cybersecurity: EICC 2025. Communications in Computer and Information Science* (Vol. 2500, pp. 324-337). (Communications in Computer and Information Science; Vol. 2500 CCIS). Springer Nature. https://doi.org/10.1007/978-3-031-94855-8_21

Copyright

No part of this publication may be reproduced or transmitted in any form, without the prior written permission of the author(s) or other rights holders to whom publication rights have been transferred, unless permitted by a license attached to the publication (a Creative Commons license or other), or unless exceptions to copyright law apply.

Take down policy

If you believe that this document infringes your copyright or other rights, please contact openaccess@vub.be, with details of the nature of the infringement. We will investigate the claim and if justified, we will take the appropriate steps.

Strengthening the MDCG Guidance on Cybersecurity for Medical Devices: A Legal Approach

Oguzhan Yesiltuna^{1,2}[0000–0002–3015–9720], Ruoxin Su^{1,2}[0009–0008–1621–1036],
Ashwinee Kumar¹[0000–0003–1249–9323], and Paul Quinn¹[0000–0002–6243–765X]

¹ Health and Ageing Law Lab (HALL), Law, Science, Technology and Society (LSTS) Research Group, Faculty of Law and Criminology, Vrije Universiteit Brussel, Pleinlaan 2, 1050 Elsene, Brussels, Belgium

² Corresponding authors: oguzhan.yesiltuna@vub.be, ruoxin.su@vub.be

Abstract. The increasing digitisation of healthcare, including the integration of connected medical devices (MDs) into healthcare systems, and the growing number of cyber threats necessitate robust cybersecurity measures for MDs to ensure patient safety, data integrity, and system functionality. The MDCG guidance on cybersecurity for MDs plays a pivotal role in aligning industrial regulatory compliance with technical standards across the EU. However, the current guidance lacks currency and consistency with the rapidly evolving EU legal framework, including data protection regulations, cybersecurity regulations, and the AI Act. Adopting a legal approach, this paper identifies the relevant significant shortcomings, examines the implications of legislative developments, and provides targeted recommendations to align the guidance with current cybersecurity frameworks. The analysis highlights the urgency of strengthening the guidance and argues that the strengthened guidance would better support stakeholders, particularly manufacturers, in safeguarding MD cybersecurity through enhancing legal clarity and practical applicability.

Keywords: Connected medical devices · MDCG · Cybersecurity · MDR · IVDR · GDPR · Data Act · EHDS · Cybersecurity Act · NIS2 Directive · Cyber Resilience Act · AI Act

1 Introduction

The Medical Device Regulation (MDR) [1] and the *In Vitro* Diagnostic Regulation (IVDR) [2] establish a robust framework for regulating medical devices (MDs) and *in vitro* diagnostic MDs (IVDMDs) within the EU. Although these regulations do not explicitly refer to *cybersecurity*, their Article 5 requires manufacturers to ensure that MD and IVDMDs meet the general safety and performance requirements set out in Annex I implicitly covering the cybersecurity aspects of such devices. The Medical Device Coordination Group (MDCG), an expert body set up by the European Commission (EC) to ensure effective and

harmonised implementation of the MDR and IVDR, provides further practical guidance on how these general requirements apply to the specific context of cybersecurity, as demonstrated by the Guidance on Cybersecurity for Medical Devices (MDCG 2019-16) [3]. It delineates the necessary measures that manufacturers must adopt to guarantee the security of their devices against cyber threats throughout the product lifecycle. Despite being an important initiative, the MDCG 2019-16 seems to be falling short of the evolving EU legal frameworks.

This paper, therefore, adopts a legal approach and aims to propose recommendations for a potential revision of MDCG 2019-16. It proceeds as follows: Section 2 briefly analyses key reasons for the imperative to revise the guidance. Sections 3-5 identify and analyse the relevant instruments within the evolving EU legal frameworks governing MD cybersecurity, revealing a significant gap in the MDCG 2019-16. Following this analysis, Section 6 offers several recommendations designed to improve the effectiveness and timeliness of the guidance. Finally, Section 7 presents authors' conclusions.

2 The Imperative to Revise MDCG 2019-16

The MD cybersecurity landscape continues to be a dynamic and evolving area. The growing interconnectedness of MDs expands the cyberattack surface for malicious actors and requires manufacturers to be more vigilant about security measures. Cyber threats such as ransomware attacks, unauthorised access, or vulnerability exploitation can be lethal when they directly target MDs [4], [41]. Additionally, as MDs become more integrated into complex hospital networks, their exposure to cyber risks escalates, requiring more robust and adaptive cybersecurity measures to protect both device functionality and sensitive patient data [5]. This has recently been the subject of high-level attention. The WHO Director-General has urged global action on cybersecurity threats to health systems, highlighting the need for coordinated efforts [6]. The EC also unveiled an Action Plan [7] specifically designed to protect hospitals and healthcare providers from cyberattacks. In order to enhance the resilience of healthcare supply chains, Action Plan charges the NIS Cooperation Group, in collaboration with the MDCG, with the execution of a comprehensive security risk assessment addressing both technical and strategic vulnerabilities. Furthermore, it encourages MD manufacturers to *voluntarily* report vulnerabilities, even though it does not address the need to revise the MDCG 2019-16 [7], [46].

The MDCG 2019-16, while a soft-law instrument, serves as a crucial document for the industry in the EU, representing the first and only guidance on the regulatory subject of MD cybersecurity [8]. It assists manufacturers on how to fulfil the relevant cybersecurity requirements of the MDR. As one of the most comprehensive guidelines available, it offers advice ranging from secure design and manufacturing principles to post-market surveillance for industry stakeholders [9]. Thus, it is imperative that the guidance be regularly updated to reflect the evolving legal landscape and ensure its practical applicability for manufacturers in addressing new cybersecurity requirements.

Following the publication of MDCG 2019-16 in December 2019 and its subsequent revision in July 2020, the legislative framework governing MD cybersecurity within the EU has undergone substantial changes (*see* Fig.1). Among the notable developments are new legislative initiatives in the areas of cybersecurity and data regulation, coupled with the nascent regulation of AI. These developments contribute to an overlapping regulatory landscape that is deficient in legislative clarification [10], [11], [12]. The MDCG 2019-16 has not been revised to reflect these significant legislative novelties, inevitably resulting in a discrepancy that may impede effective compliance and risk management practices. Moreover, the guidance even failed to sufficiently address certain pre-existing and essential EU laws, including the General Data Protection Regulation (GDPR) [13] and the Network and Information Systems (NIS) Directive [14]. This misalignment calls for a comprehensive review of the MDCG 2019-16 to ensure its consistency with contemporary cybersecurity requirements.

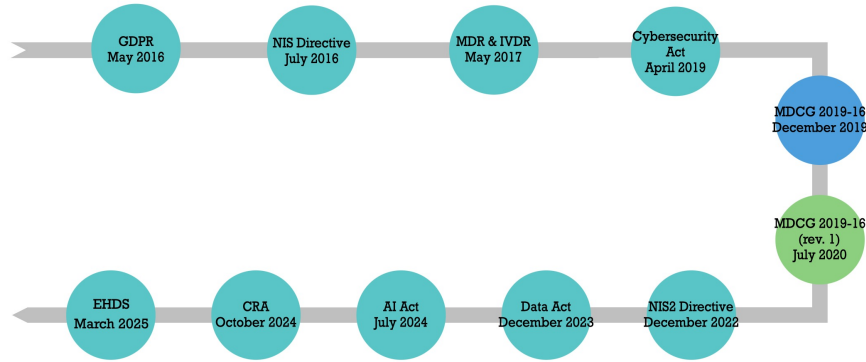


Fig. 1. Legislative developments related to MD cybersecurity (according to publication date in the Official Journal) and the MDCG 2019-16

Recent scholarship and industry feedback consistently highlight the limitations of current guidance in adequately addressing the emerging regulatory challenges related to MD cybersecurity [12], [15], [16], [17]. Academic studies have identified inconsistencies in definitions, a lack of clarity regarding stakeholder responsibilities, and insufficient consideration of the interplay among relevant EU laws within the guidance [12], [17]. Appropriate guidance is crucial for manufacturers as they navigate the complex legal landscape and the proliferation of new legislative initiatives [15]. The convergence of scholarly critique and industry demand further reinforces the imperative for MDCG to update the guidance.

3 Evolving EU Legal Framework on Data

3.1 GDPR

A key pillar of EU data-related legislation is the GDPR, which came into effect on 25 May 2018 [13]. Although GDPR is often viewed primarily as a data protection regulation, its requirements also have significant implications for the overall cybersecurity of connected MDs. By mandating strict protections for personal data stored within these devices, the GDPR effectively integrates data privacy measures into broader system cybersecurity considerations. It also aligns with the formal definition of cybersecurity in the EU law (*see* Section 4.1), which also includes the protection of affected individuals. While MDCG 2019-16 acknowledges the applicability of GDPR, its coverage remains limited and lacks comprehensive guidance on its intersection with other EU legislation, notably the MDR and the IVDR.

The GDPR applies to the processing of personal data relating to an identified or identifiable individual, excluding anonymised data and data that cannot be attributed to a specific person [13]. Notably, data revealing one’s health status, genetic data and biometric data are classified as sensitive personal data, subject to strengthened safeguards and stringent processing requirements [13]. This is particularly relevant for connected MDs, which inevitably collect and process sensitive patient data, such as health metrics, vital signs, and wellbeing indicators, to achieve their intended medical purposes. Under the GDPR, data subjects are granted extensive rights, such as the right to access and the right to data portability (only where consent or contract is used as legal basis for personal data processing), reinforcing their autonomy over data processed by controllers. When a MD manufacturer directly manages the processing of data collected by its devices, it becomes a data controller under the GDPR and may need to deal with various data-related requests from users, such as data access. Nevertheless, enabling patient access to device-generated data may inadvertently heighten cybersecurity risks, including potential vulnerabilities to hacking, data interception, or system exploitation [18]. This underscores the urgent need for consistent regulations and interpretive guidance that can help balance individual rights with the security and integrity of MDs.

3.2 Data Act

Following GDPR, another important data regulation applicable to MDs is the Data Act [19]. Entered into force in January 2024 as key component of the EU’s digital strategy, the Data Act establishes cross-sectoral rules governing fair access to and use of data, fostering innovation and enabling the EU’s digital transformation [20]. It empowers users to access and share IoT-generated data, allows public sector emergency access to private data, protects businesses from unfair contractual terms, facilitates cloud provider switching, and safeguards against non-EU data access requests [20]. Complementing the Data Governance

Act (DGA) [21], it promotes interoperability standards and will fully apply from 12 September 2025.

The Data Act provides harmonised rules for fair data access and utilisation across three operational frameworks: business-to-consumer (B2C), business-to-business (B2B), and business-to-government (B2G), with cross-sectoral applicability, including MDs. As a horizontal legislation, it governs data interactions in the healthcare sector while permitting sector-specific vertical regulations to address specialised requirements (e.g., the MDR and IVDR at the EU level) [22]. Recital 14 explicitly integrates MDs into the scope, encompassing health monitoring equipment (e.g. wearables, pacemakers) and diagnostic tools (e.g. MRI scanners), thereby affirming their classification as connected products under the Data Act. The Act delineates dynamic roles, i.e., user, data holder, and data recipient, which may overlap in healthcare settings. For instance, hospitals may act as users *vis-à-vis* device manufacturers while serving as data holders for patient-generated data [23]. Notably, the Data Act’s role-based framework diverges from the GDPR’s data subject-controller-processor trinity, reflecting the complexity of healthcare ecosystems where institutional users (e.g., healthcare providers) are not necessarily GDPR data subjects. This statutory distinction demonstrates the need for nuanced compliance strategies to address normative overlaps in medical data governance.

3.3 Regulation on the European Health Data Space (EHDS)

The EHDS [24], the most recent addition to the EU data regulations, entered into force on 26 March 2025. Driven by the EC’s ambition and commitment to a Health Union, the EHDS builds upon the foundations laid by the GDPR, the DGA, the Data Act, the MDR and the IVDR. It pursues the objectives of enhancing the patient control over their health data and the data exchange for the healthcare delivery (primary use of health data), establishing rules to promote the reliability, security, and interoperability of electronic health record (EHR) systems, and laying down rules for the secondary use of health data [25], [26].

The EHDS is relevant particularly for two reasons: First, certain software components of EHR systems and wellness applications may fall under the scope of MDR and IVDR and thus require certification in accordance with the respective regulations. The EHDS’s essential requirements on interoperability set out in Annex II, including the requirements for security and logging, apply to MDs, IVDMDs and wellness applications providing electronic health data to be processed as part of the EHR system, to the extent that their manufacturer claims interoperability with such system. Second, both the minimum categories of electronic health data for secondary use and the purposes for which such data can be processed for secondary use relate to MDs. Personal electronic health data automatically generated through MDs, data from clinical trials, clinical studies, clinical investigations and performance studies subject to the MDR and IVDR, and other health data from MDs are listed among the minimum categories of electronic health data to be made available for secondary use [24]. Electronic

health data can be processed for secondary use with the aim of training, testing, and evaluation of algorithms, including in MDs, IVDMDs, AI systems, and digital health applications [24]. Data sharing is permissible only within secure processing environments, the security requirements of which are governed by the EHDS. These two aspects highlight the necessity of integrating the EHDS’s interaction with other regulations relevant to MD cybersecurity into the guidance.

4 Evolving EU Legal Framework on Cybersecurity

4.1 Cybersecurity Act (CSA)

The CSA [27], effective since June 2019, aims to enhance the mandate of the European Union Agency for Cybersecurity (ENISA) and establish cybersecurity certification schemes for ICT products (e.g., networked MDs), services (e.g., cloud-based healthcare platforms), and processes (e.g., vulnerability management). The CSA’s significance lies in its introduction of a formal, EU-level definition of cybersecurity, encompassing the protection of networks, systems, and individuals from cyber threats. It adopts a rights-based approach distinct from the technical “CIA triad” (confidentiality, integrity, availability) under the NIS Directive, recognising it both as a *praxis* and as a *state*, extending protection beyond systems to include affected users [28]. In April 2023, the EC proposed expanding certification to managed security services, addressing risk management and incident response, which gained provisional approval in March 2024 [29].

A key advancement under the CSA is the establishment of European cybersecurity certification schemes, designed to ensure compliance with security requirements and bolster trust in ICT products. These schemes employ a risk-based approach, classifying assurance levels as basic (documentation review), substantial (security functionality verification), and high (resilience testing against advanced threats) to enhance transparency and consumer confidence. The first major certification is the European Cybersecurity Scheme on Common Criteria (EUCC), which was adopted in January 2024 and became effective from February 2025 [30]. The EUCC scheme will apply on a voluntary basis within the EU and focus on certifying the cybersecurity of all types of ICT products in their lifecycle, such as biometric systems and encrypted storage [31]. Despite these advancements, potential overlaps still exist where the CSA’s horizontal scope intersects with sector-specific regulations, such as the MDR. Connected MDs classified as ICT products, for instance, may be required to comply with both the MDR’s CE marking, which incorporates cybersecurity risk management provisions, and the CSA’s certification framework [32], leading to industry concerns about regulatory fragmentation. Although the MDCG 2019-16 acknowledges the CSA’s importance for its EU-wide cybersecurity certification framework for ICT products, the applicability of this framework to MDs and its reconciliation with existing regulations remain unclear, thus complicating implementation.

4.2 NIS and NIS2 Directives

The NIS Directive was the first EU-wide legislative piece focused on improving cybersecurity across the EU. Implemented by EU Member States by 9 May 2018, it targeted operators of essential services and digital service providers. However, its minimum harmonization approach resulted in divergent practices among Member States regarding incident reporting, security requirements, and information sharing [33]. While MDCG 2019-16 recognises the importance of NIS Directive in addressing MD cybersecurity, its engagement with the regulation is minimal, limited to a brief mention of its legislative objectives.

Due to its shortcomings, the EC proposed the NIS2 Directive [34], which entered into force on 16 January 2023. Compared to its predecessor, NIS2 introduces significant changes, including expanded scope, stricter security measures, clearer incident reporting guidelines [35], enhanced Member State cooperation, and reduced Member State discretion [36]. NIS2 aligns with the CSA's definition of *cybersecurity* and replaces *operators of essential services* with *essential and important entities*. Notably, it designates the health sector including healthcare providers and manufacturers of critical MDs during a public health emergency as *high criticality* and the manufacturing sector encompassing MD manufacturers as *critical*. These updated provisions are to be transposed into national law by 17 October 2024, which still entails a degree of minimum harmonisation across the EU.

NIS2, as a horizontal cybersecurity legislative instrument, may regulate the cybersecurity of certain sectors in parallel with sector-specific legislation at the EU level. In this context, NIS2 functions as *lex generalis*, while sector-specific legislation, including MDR, IVDR, and EHDS, acts as *lex specialis* [37]. However, it remains uncertain whether the MDR can be considered functionally equivalent to NIS2, thus raising doubts about its suitability as a *lex specialis* in cybersecurity. Moreover, incident notification requirements overlap between NIS2 and MDR. The potential applicability of the GDPR data breach notification requirements to connected MDs further complicates the regulatory landscape, leading to a proliferation of supervisory authorities [12]. For MD manufacturers, these overlapping regulatory frameworks may lead to divergent notification and reporting requirements, underscoring the need for further clarification and regulatory guidance on this matter.

4.3 Cyber Resilience Act (CRA)

Following the CSA and NIS2, the EC also proposed for a regulation on horizontal cybersecurity requirements for products with digital elements on 15 September 2022. The proposal was finally agreed upon by the EU co-legislators as CRA [38] and it was published in the Official Journal on 23 October 2024. The CRA seeks to improve cybersecurity by setting essential requirements for product design, development, and production, along with vulnerability management obligations for economic operators. It categorises products with digital elements as *important* or *critical*, requiring stricter conformity assessments based on cybersecurity

risk. While MDs and IVDMDs are excluded due to existing MDR and IVDR provisions, healthcare-related software and wearable health-monitoring products outside their scope remain subject to the CRA. These digital health products must adhere to essential security requirements, including security-by-design, prevention of unauthorised access, data confidentiality and integrity, and resilience against cyber threats.

5 Nascent EU Legal Framework on AI: AI Act

Entered into force on 1 August 2024, the AI Act [39] is the first comprehensive regulation which sets legally binding standards for the placing on the market, the putting into service, and the use of AI systems. Being a horizontal legislation, it imposes requirements for all AI systems according to their risks, regardless of the sector. As per Article 6, products or safety components of products that are required to undergo a third-party conformity assessment by the Union harmonisation legislation listed in Annex I are classified as high-risk [39]. Annex I covers the MDR and the IVDR. This broadly implies that MDs that incorporate AI to achieve their intended purpose (AI-enabled MDs) with risk class IIa or higher are classified high-risk under the AI Act.

AI Act requires that high-risk AI systems shall be designed and developed in such a way that they achieve an appropriate level of cybersecurity and that they perform consistently in this respect throughout their lifecycle. When compared for AI-enabled MDs, it seems that MDR’s general safety and performance requirements, thanks to their technology-neutral formulation, already covers the cybersecurity risks that AI Act aims to address. The AI Act re-imposing requirements that exist under the sector-specific legislation seems to increase the compliance burden for innovators without putting a new layer of protection, at least for AI-enabled MDs. Article 42 of the AI Act introduces a presumption of conformity for high-risk AI systems that have been certified or for which a statement of conformity has been issued under the CSA. However, the lack of a presumption in the MDR similar to that in the AI Act and the voluntariness of the certification mechanism of the CSA do not entirely eliminate the overlap. One solution for the cybersecurity of AI-enabled MDs could have been for the AI Act to adopt the MDR as *lex specialis*, which functions with highly detailed technical standards. Another solution could have been to adopt the model between the MDR and machinery legislation: When a device is covered by both legislation, the requirements of the latter apply to the extent that they are more specific [40].

Further elaboration is required on several other contentious points: This is due to the fact that although both the MDR and the AI Act are part of product safety legislation, they adopt some different terms (e.g. *manufacturer* v. *provider*, *user* (*healthcare professional and lay person*) v. *deployer*; which may be or not the same person) or definitions (e.g. serious incident). For instance, the AI Act’s lack of lay person definition may result in users of self-testing devices being subject to cybersecurity obligations [40]. Moreover, the notification mechanisms

for a serious incident (e.g. a cyber-attack on an AI-enabled MD) under the two regulations also differ in a way that is likely to create confusion [32].

6 Recommendations for Strengthening the MDCG 2019-16

European medical device regulatory system lacks a centralised authority that oversees the implementation of MDR and IVDR at the EU level. In such absence, the MDCG acts as an expert committee. Both the MDR and the IVDR task the MDCG to contribute to the development of guidance aimed at ensuring effective and harmonised implementation, including the application of the general safety and performance requirements. The MDCG is also tasked with providing advice in the assessment of *any* issue related to the implementation and contributing to harmonised administrative practice with regard to devices in the Member States [1], [2]. Nevertheless, the MDCG has only advisory power, which creates the limitation that its guidance is non-binding. It would, therefore, be preferable to clarify the interactions between legal frameworks with legislative revision or the Court of Justice of the European Union’s interpretation having binding force. There are some developments related to the former. The EC President von der Leyen’s Mission Letter [42] to the Commissioner-designate for Health and Animal Welfare explicitly refers to the Draghi report [43], to stress test the EU legislation and table proposals to eliminate any overlaps and contradictions. Following this, the European Parliament (EP) has also adopted a resolution on the urgent need to revise the MDR [44]. In this context, it should be noted that there are even proposal initiatives, including the establishment of a central office at the EU level [45]. However, as the identified frameworks involve multiple regulations, clarifying the interaction of these regulations may require efforts beyond the MDR revision. Even given these limitations, there is still room to strengthen MDCG 2019-16 by taking into account the existing applicable legal frameworks. Considering these limitations of the MDCG and based on the shortcomings of the MDCG 2019-16 regarding its engagement with the identified legal frameworks, our recommendations are as follows:

Incorporate the identified legal frameworks governing MD cybersecurity: The guidance should not merely acknowledge the regulations but should fully integrate them into the MD cybersecurity framework. This should include a detailed explanation of the applicability of the relevant regulation to MDs.

Include or refer to the core concepts regulated under the identified legal frameworks: This covers including but not limited to “cybersecurity”, “cyber threat”, “security-by-design”, and “security-by-default” defined under the CSA, “network and information system”, “security of network and information systems”, and “incident” defined under the NIS2, “data concerning health”, “integrity and confidentiality” principle, strengthened protection regime for health data, “data protection by design and by default”, and “security of processing” under the GDPR.

Map cybersecurity requirements of the identified legal frameworks for MDs and acknowledge the overlaps and inconsistencies between these frameworks: MDCG 2019-16 should offer a map of the cybersecurity requirements of all applicable regulations. It should also explicitly acknowledge the overlaps and inconsistencies (i.e. incident reporting requirements) between these regulations. This would serve transparency, which is crucial for building trust and ensuring that stakeholders are aware of the complexities and urge authorities with binding power to take action.

Where possible, provide further practical guidance and contextualised interpretation in cooperation with relevant actors: Given that the MDCG is established under the MDR and the IVDR, its primary focus should be on providing guidance that supports the implementation of these regulations. However, as MD cybersecurity is a multifaceted concept, it is recommended that MDCG work with other relevant stakeholders, such as the ENISA, the NIS Cooperation Group, the European AI Board, the European Data Protection Board, the European Data Protection Supervisor, and the European Data Innovation Board, to provide an interpretation of horizontal legislation adapted to MD cybersecurity.

Incorporate dedicated guidance for small and medium-sized enterprises (SMEs): To ensure the updated MDCG 2019-16 remains practical and inclusive, it is recommended that dedicated guidance for SMEs should be incorporated, recognizing that these organizations form a substantial part of the MD manufacturing sector yet often operate with limited financial and technical resources. For example, the updated guidance could offer scaled compliance pathways and targeted support (such as accessible technical guidelines, regulatory mapping tools and training materials) for SMEs. Collaborative partnerships among SMEs, industry bodies, and regulators could also be encouraged.

By implementing these recommendations, the MDCG 2019-16 can be strengthened to provide greater clarity for MD manufacturers, promote a more harmonized approach to MD cybersecurity, and ultimately enhance the safety and security of both individuals and MDs in the EU.

7 Conclusion

This paper has demonstrated the critical need for a comprehensive revision of the MDCG 2019-16. The analysis of the evolving EU legal frameworks, encompassing data protection regulations, cybersecurity regulations, and the AI Act, reveals significant gaps and inconsistencies in the current guidance. Such shortcomings may pose a risk to MD security, patient safety, and innovation economy. Based on this analysis, the paper has proposed several concrete recommendations to strengthen the MDCG 2019-16. These recommendations aim to enhance its legal clarity, currency, and consistency, and to improve its practical utility for manufacturers. By incorporating these recommendations, the MDCG 2019-16 can serve as a more effective tool for promoting robust cybersecurity practices within the MD sector, ultimately enhancing patient safety and public health.

Acknowledgments. This work was supported by the European Commission under the Horizon Europe Program, as part of the project CYMEDSEC (101094218). Views and opinions expressed are, however, those of the author only and do not necessarily reflect those of the European Union. Neither the European Union, nor the granting authorities, can be held responsible for them. Responsibility for the information and views expressed therein lies entirely with the authors.

Disclosure of Interests. The authors have no competing interests to declare.

References

1. EU: Regulation (EU) 2017/745 of the European Parliament and of the Council of 5 April 2017 on medical devices, amending Directive 2001/83/EC, Regulation (EC) No 178/2002 and Regulation (EC) No 1223/2009 and repealing Council Directives 90/385/EEC and 93/42/EEC (Text with EEA relevance). (2017).
2. EU: Regulation (EU) 2017/746 of the European Parliament and of the Council of 5 April 2017 on in vitro diagnostic medical devices and repealing Directive 98/79/EC and Commission Decision 2010/227/EU (Text with EEA relevance). (2017).
3. Medical Device Coordination Group: MDCG 2019-16 Guidance on cybersecurity for medical devices (Rev. 1). (2019).
4. Pycroft, L., Aziz, T. Z.: Security of implantable medical devices with wireless connections: The dangers of cyber-attacks. *Expert Review of Medical Devices*, 15(6), 2018, 403–406. <https://doi.org/10.1080/17434440.2018.1483235>
5. Williams, P.A., Woodward, A.J.: Cybersecurity vulnerabilities in medical devices: a complex environment and multifaceted problem. *Medical Devices: Evidence and Research*. 8, 305–316 (2015). <https://doi.org/10.2147/MDER.S50048>.
6. WHO: WHO Director-General’s remarks at Meeting of the UN Security Council on threats posed by ransomware attacks against hospitals and other health-care facilities and services. (2024).
7. EC: Commission unveils action plan to protect the health sector from cyberattacks. (2025).
8. Freyer, O., Jahed, F., Ostermann, M., Rosenzweig, C., Werner, P., Gilbert, S.: Consideration of Cybersecurity Risks in the Benefit-Risk Analysis of Medical Devices: Scoping Review. *J Med Internet Res*. 26, e65528 (2024). <https://doi.org/10.2196/65528>.
9. Biasin, E., Kamenjašević, E.: Regulatory Approaches Towards AI-Based Medical Device Cybersecurity: A Transatlantic Perspective. *Eur. j. risk regul.* 1–11 (2024). <https://doi.org/10.1017/err.2024.23>.
10. Scherb, C., Hadayah, A., Heitz, L.B.: CyMed: A Framework for Testing Cybersecurity of Connected Medical Devices, <http://arxiv.org/abs/2310.03583>, (2023).
11. Biasin, E., Yaşar, B., Kamenjašević, E.: New Cybersecurity Requirements for Medical Devices in the EU: The Forthcoming European Health Data Space, Data Act, and Artificial Intelligence Act. *Law Tech Hum.* 5, 43–58 (2023). <https://doi.org/10.5204/lthj.3068>.
12. Biasin, E., Kamenjašević, E.: Cybersecurity of Medical Devices: Regulatory Challenges in the European Union. In: Cohen, I.G., Minssen, T., Price Ii, W.N., Robertson, C., and Shachar, C. (eds.) *The Future of Medical Device Regulation*. pp. 51–62. Cambridge University Press (2022). <https://doi.org/10.1017/9781108975452.005>.

13. EU: Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation). (2016).
14. EU: Directive (EU) 2016/1148 of the European Parliament and of the Council of 6 July 2016 concerning measures for a high common level of security of network and information systems across the Union (NIS Directive). (2016).
15. Taylor, S., Gilje Jaatun, M., Bernsmed, K., Androutsos, C., Frey, D., Favrin, S., Rodrigues, J., Milojević, D., Karras, D., Siachos, I., Epiphaniou, G., Moukafih, N., Messinis, S., Rallis, I., Protonotarios, N., Gedeon, P., Castillo, A., Maple, C., Matragkas, N., DeLong, R., Arvanitis, T., Katzis, K.: A Way Forward for the MDCG 2019-16 Medical Device Security Guidance. In: Proceedings of the 17th International Conference on Pervasive Technologies Related to Assistive Environments. pp. 593–599. ACM, Crete Greece (2024). <https://doi.org/10.1145/3652037.3663894>.
16. Rak, R., Quinn, P.: Enhancing Digital Health Innovation in the EU with Effective Industrial Strategy Policies. Joint Research Centre of the European Commission (2024).
17. Milojević, D.: Is it time to update the Medical Device Coordination Group’s Guidance on Cybersecurity for Medical Devices?, <https://www.law.kuleuven.be/citip/blog/is-it-time-to-update-the-medical-device-coordination-groups-guidance-on-cybersecurity-for-medical-devices/>.
18. Cohen, I.G., Gerke, S., Kramer, D.B.: Ethical and Legal Implications of Remote Monitoring of Medical Devices. *The Milbank Quarterly*. 98, 1257–1289 (2020). <https://doi.org/10.1111/1468-0009.12481>.
19. EU: Regulation (EU) 2023/2854 of the European Parliament and of the Council of 13 December 2023 on harmonised rules on fair access to and use of data and amending Regulation (EU) 2017/2394 and Directive (EU) 2020/1828 (Data Act) (Text with EEA relevance). (2023).
20. EC: European Data Act enters into force, putting in place new rules for a fair and innovative data economy, <https://digital-strategy.ec.europa.eu/en/news/european-data-act-enters-force-putting-place-new-rules-fair-and-innovative-data-economy>.
21. EU: Regulation (EU) 2022/868 of the European Parliament and of the Council of 30 May 2022 on European data governance and amending Regulation (EU) 2018/1724 (Data Governance Act). (2022).
22. Biasin, E.: The Data Act will concern eHealth apps and Medical Devices, <https://www.law.kuleuven.be/citip/blog/the-data-act-will-concern-ehealth-apps-and-medical-devices/>.
23. De Pauw, V., De Cordier, T., Fonteyn, B., Wiring, R.: Adapting to the new EU Data Act: implications for medical devices and other health devices, <https://cms-lawnow.com/en/ealerts/2024/01/adapting-to-the-new-eu-data-act-implications-for-medical-devices-and-other-health-devices>.
24. EU: REGULATION OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL on European Health Data Space and amending Directive 2011/24/EU and Regulation (EU) 2024/2847. (2025).
25. Li, W., Quinn, P.: The European Health Data Space: An expanded right to data portability? *Computer Law & Security Review*. 52, (2024). <https://doi.org/10.1016/j.clsr.2023.105913>.
26. Quinn, P., Ellyne, E., Yao, C.: Will the GDPR Restrain Health Data Access Bodies Under the European Health Data Space (EHDS)? *Computer Law & Security Review*. 54, (2024). <https://doi.org/10.1016/j.clsr.2024.105993>.

27. EU: Regulation (EU) 2019/881 of the European Parliament and of the Council of 17 April 2019 on ENISA (the European Union Agency for Cybersecurity) and on information and communications technology cybersecurity certification and repealing Regulation (EU) No 526/2013 (Cybersecurity Act) (2019).
28. Papakonstantinou, V.: Cybersecurity as praxis and as a state: The EU law path towards acknowledgement of a new right to cybersecurity? *Computer Law & Security Review*. 44, 105653 (2022). <https://doi.org/10.1016/j.clsr.2022.105653>.
29. Mammonas, D.: Cyber solidarity package: Council and Parliament strike deals to strengthen cyber security capacities in the EU, <https://www.consilium.europa.eu/en/press/press-releases/2024/03/06/cyber-solidarity-package-council-and-parliament-strike-deals-to-strengthen-cyber-security-capacities-in-the-eu/>.
30. EU: Commission Implementing Regulation (EU) 2024/482 of 31 January 2024 laying down rules for the application of Regulation (EU) 2019/881 of the European Parliament and of the Council as regards the adoption of the European Common Criteria-based cybersecurity certification scheme (EUCC) (C/2024/560). (2024).
31. EC: The EU cybersecurity certification framework, <https://digital-strategy.ec.europa.eu/en/policies/cybersecurity-certification-framework>.
32. Biasin, E., Kamenjašević, E., Rosager, K.: Cybersecurity of AI medical devices: risks, legislation, and challenges. In: Solaiman, B. and Cohen, I.G. (eds.) *Research Handbook on Health, AI and the Law*. pp. 57–74. Edward Elgar Publishing (2024).
33. EC: COMMISSION STAFF WORKING DOCUMENT IMPACT ASSESSMENT REPORT Accompanying the document Proposal for a Directive of the European Parliament and of the Council on measures for a high common level of cybersecurity across the Union, repealing Directive (EU) 2016/1148. (2020).
34. Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union, amending Regulation (EU) No 910/2014 and Directive (EU) 2018/1972, and repealing Directive (EU) 2016/1148 (NIS 2 Directive) (2022).
35. Schmitz-Berndt, S.: Refining the Mandatory Cybersecurity Incident Reporting Under the NIS Directive 2.0: Event Types and Reporting Processes. In: Onwubiko, C., Rosati, P., Rege, A., Erola, A., Bellekens, X., Hindy, H., and Jaatun, M.G. (eds.) *Proceedings of the International Conference on Cybersecurity, Situational Awareness and Social Media*. pp. 343–351. Springer Nature Singapore, Singapore (2023).
36. P. Wanecki, R. Jašek, I. Drofova: The Contribution of the European NIS2 Directive to the Design of the Cyber Security Model. In: 2023 International Conference on Information and Digital Technologies (IDT). pp. 149–154 (2023). <https://doi.org/10.1109/IDT59031.2023.10194454>.
37. Vandezande, N.: Cybersecurity in the EU: How the NIS2-directive stacks up against its predecessor. *Computer Law & Security Review*. 52, 105890 (2024). <https://doi.org/10.1016/j.clsr.2023.105890>.
38. EU: Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act). (2024).
39. Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence and amending Regulations (EC) No 300/2008, (EU) No 167/2013, (EU) No 168/2013, (EU) 2018/858, (EU) 2018/1139 and (EU) 2019/2144 and Directives 2014/90/EU, (EU) 2016/797 and (EU) 2020/1828 (Artificial Intelligence Act) (Text with EEA relevance) (2024).

40. Choi, W., van Eck, M., van der Heijden, C., Hooghiemstra, T., Vollebregt, E.: Legal Analysis: European Legislative Proposal Draft AI Act and MDR/IVDR. (2022).
41. Levy-Loboda, T., Sheetrit, E., Liberty, I.F., Haim, A., Nissim, N.: Personalized insulin dose manipulation attack and its detection using interval-based temporal patterns and machine learning algorithms. *Journal of Biomedical Informatics*, 132, 2022, <https://doi.org/10.1016/j.jbi.2022.104129>.
42. EC: Mission Letter, <https://commission.europa.eu/about/commission-2024-2029/commissioners-designate-2024-2029>.
43. EC: The Draghi report on EU competitiveness, <https://commission.europa.eu/topics/eu-competitiveness/draghi-report>.
44. EP: Resolution of 23 October 2024 on the urgent need to revise the Medical Devices Regulation, P10 TA(2024)0028.
45. Liese Initiative, <https://peter-liese.de/en/32-english/press-releases-en/4251-epp-revision-of-the-medical-device-regulation-can-save-lives>.
46. Yesiltuna, O.: A Prescription for Resilience? European Action Plan on the Cybersecurity of Hospitals and Healthcare Providers, <https://hall.research.vub.be/a-prescription-for-resilience-european-action-plan-on-the-cybersecurity-of-hospitals-and-healthcare>.